

Security Evaluation

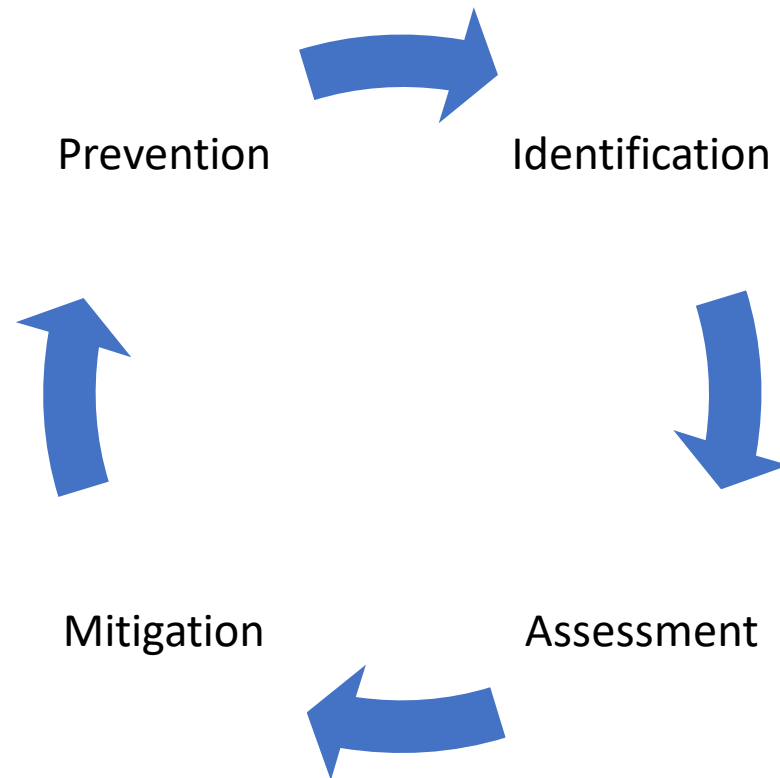


Shweta A. Chawla
Founder & Investigator
SC Cyber Solutions



Security Evaluation

- ❶ The examination of a system to determine its degree of compliance with a stated security model, security standard, or specification.
- ❷ The evaluation may be conducted
 - ❶ by analyzing the detailed design, especially of the software, often using verification and validation
 - ❶ by observing the functional behavior of the system
 - ❶ by attempting to penetrate the system using techniques available to an attacker



Why are Security Evaluations Important



- 🔴 Identify assets
- 🔴 Enable the IT team to identify areas of weakness and opportunities for growth in security protection
- 🔴 Identify and secure sensitive data
- 🔴 Understands where current vulnerabilities exist
- 🔴 Prioritise these vulnerabilities
- 🔴 Make informed decisions about security and training expenses
- 🔴 Build contingency plans
- 🔴 Meet compliance requirements
- 🔴 Update, improve cybersecurity policies and procedures



- 🦊 Access control and user account management
- 🦊 Information security governance and risk management
- 🦊 Improved workstation and device security
- 🦊 Business continuity and disaster recovery planning
- 🦊 Cryptography
- 🦊 Physical (environmental) security
- 🦊 Network and operations security
- 🦊 Security architecture and design

Asset Management



- ❶ Asset management is the process of identifying, on a continuous, real-time basis, the IT assets that your organization owns and the potential security risks or gaps that affect each one
- ❷ An asset is anything of value to a business
- ❸ And /or anything of value that supports the business and its operations
- ❹ In the case of security audits, this asset is one that relates to information services



- ❶ Information asset
 - ❧ Information stored in any form
 - ❧ A dataset of information arranged and managed as a single, valuable entity
- ❷ Physical asset
 - ❧ Equipment that add value
- ❸ People asset
 - ❧ People working within the organization with access to information
- ❹ Critical asset
 - ❧ Any of the above
 - ❧ Important to maintain functioning of the business

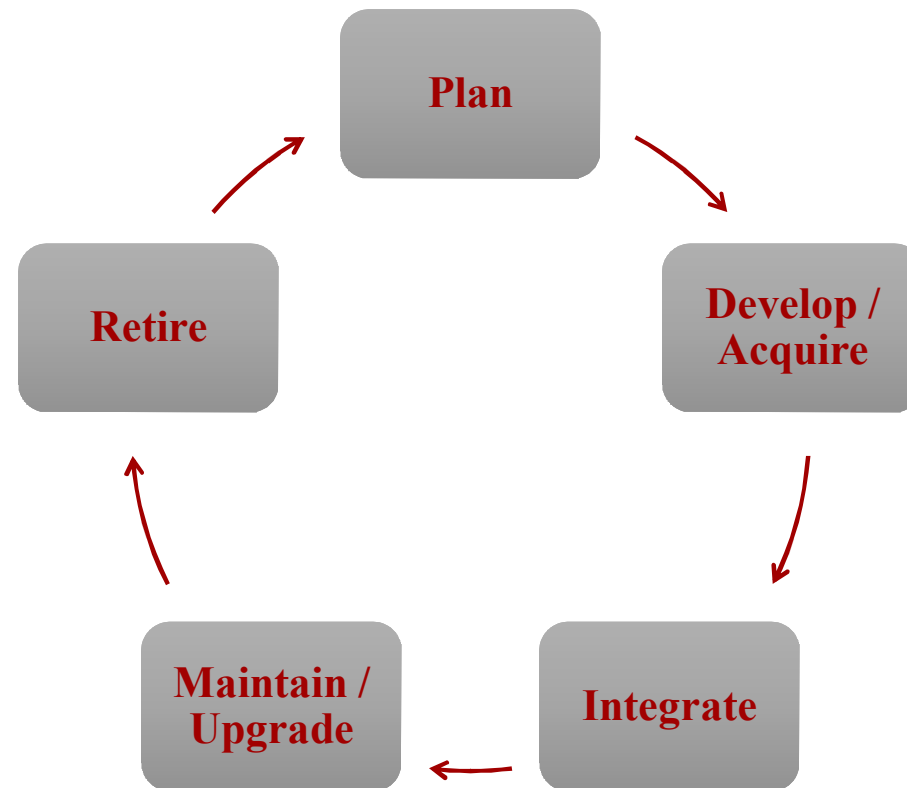
Importance of Asset Management



- 🦊 Identify the assets and the threats they face
- 🦊 Manage the risks associated with threats
- 🦊 Streamlines asset security
- 🦊 Create faster incident response processes



IT Asset Lifecycle





Asset Management



Asset Management



- ❶ A sample list of information to gather per asset
 - ❧ Software
 - ❧ Hardware
 - ❧ Data
 - ❧ Interfaces
 - ❧ Users
 - ❧ Support personnel
 - ❧ Mission or purpose
 - ❧ Criticality
 - ❧ Functional requirements
 - ❧ IT security policies
- ❧ IT security architecture
- ❧ Network topology
- ❧ Information storage protection
- ❧ Information flow
- ❧ Technical security controls
- ❧ Physical security environment
- ❧ Environmental security

Risk



- 🦊 The possibility that something bad might happen
- 🦊 Effect, impact of this is usually uncertain
- 🦊 The nature of risk is generally subjective

Cyber Risk

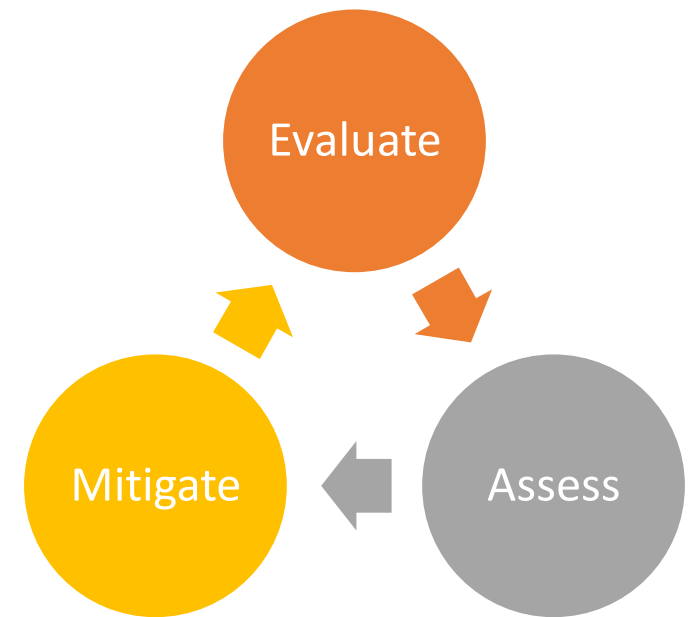


- ❶ The potential for an unplanned, negative business outcome involving the failure or misuse of IT
- ❷ Risk of financial loss, disruption or damage to the reputation of an organization from some sort of failure of its information technology systems
- ❸ Types of risk
 - ❶ Strategic
 - ❷ Operational
 - ❸ Financial
 - ❹ External

Risk Management Components



- 🦉 Evaluation, to identify assets and evaluate their properties and characteristics
- 🦉 Risk assessment, to discover threats and vulnerabilities that pose risk to assets
- 🦉 Risk mitigation, to address risk by transfer-ring, eliminating or accepting it



Risk Management



- ❶ Process of identifying, assessing and controlling threats
- ❷ Studies the relationship between risks and impacts

Risk Threshold

Risk Appetite

Risk Tolerance

Unacceptable Risk





Risk Management Process





- ❶ Risk
 - ❧ Potential for loss, damage, destruction of assets

- ❷ Vulnerability
 - ❧ Weakness in the system, asset, procedure

- ❸ Threat
 - ❧ Exploits a vulnerability
 - ❧ Can destroy, damage or disrupt an asset

- ❹ Exploit
 - ❧ Use something for an advantage
 - ❧ A piece of software, a chunk of data, or a sequence of commands that takes advantage of a bug or vulnerability to cause unintended or unanticipated behavior to occur on computer software, hardware, or something electronic

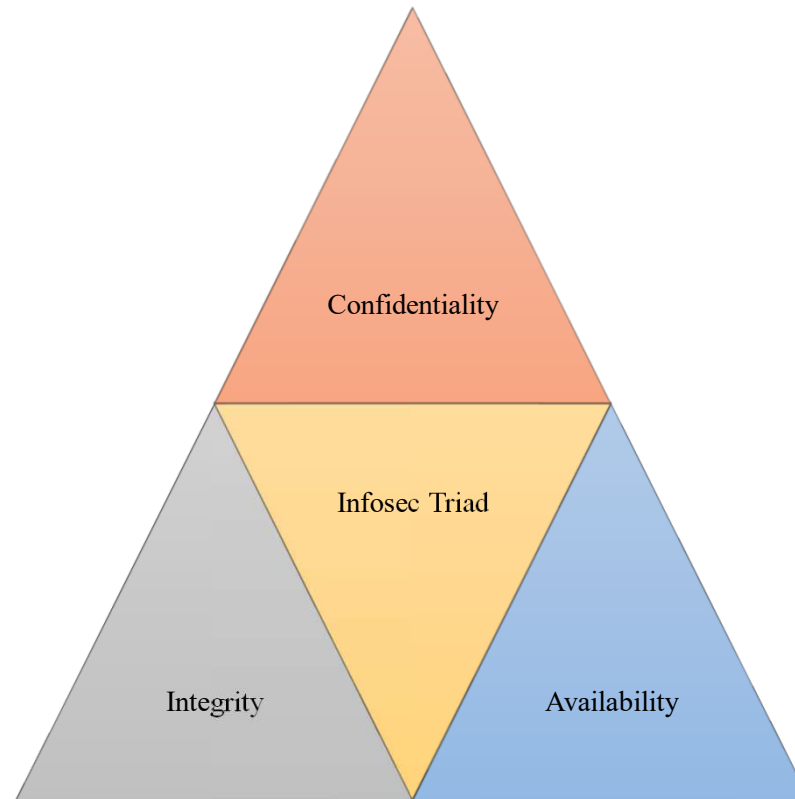
IT Security Risk Assessment



- ❶ Identify assets
- ❷ Identify risks
- ❸ Identify threats
 - ❖ Threat $\Rightarrow$ Vulnerability $\Rightarrow$ Risk realized
- ❹ Identify vulnerabilities
- ❺ Develop metrics
 - ❖ Asset X Threat X Vulnerability = Risk
- ❻ Consider historical breach data
- ❼ Calculate cost
- ❽ Perform risk to asset tracking



Assessment Parameters





Methodology			
Threat	Likelihood	Impact	Risk
Loss of confidentiality			
Loss of integrity			
Loss of availability			
		Overall Risk	

Risk level = Likelihood X Impact



Calculate Risk Level

		Impact →				
		Negligible	Minor	Moderate	Significant	Severe
Likelihood ↑	Very Likely	Low	Moderate	High	High	High
	Likely	Low	Moderate	Moderate	High	High
	Possible	Low	Low	Moderate	Moderate	High
	Unlikely	Low	Low	Moderate	Moderate	Moderate
	Very Unlikely	Low	Low	Low	Moderate	Moderate



Threat Matrix

- ❶ Risk assessment matrix
- ❷ Probability and Severity risk matrix
- ❸ Visual tool that depicts the potential risks affecting a business
- ❹ The risk matrix is based on two intersecting factors:
 - ❶ the *likelihood* that the risk event will occur,
 - ❷ the potential *impact* that the risk event will have on the business
- ❺ ∴ it helps visualize probability vs severity of a potential risk

Importance of Threat Matrix



- 🦊 Prioritisation of risk
- 🦊 Strategic implementation of risk management
- 🦊 Realistic view of risk posture



Threat Matrix

Threat Matrix							
<u>Threats</u> \ <u>Vulnerabilities</u>	Firewalls	Databases	Application Architecture	Physical Security	Insecure Wireless	Internet-based service (Like VPN)	Total Score
<i>Intrusion (Hacking, Password Attacks)</i>	9	3	9	9	9	3	42
<i>Insider Attacks</i>	3	3	3	9	3	1	22
<i>DDoS</i>	9	0	9	1	3	3	25
<i>Theft of Hardware</i>	1	1	1	9	3	1	16



Threat	Vulnerability	Asset	Impact	Likelihood	Risk	Control Recommendations
System failure — Overheating in server room High	Air-conditioning systems is ten years old. High	Servers Critical	All services (website, email, etc.) will be unavailable for at least 3 hours. Critical	High Current temperature in server room is 40C	High Potential loss of \$50,000 per occurrence	Buy a new air conditioner, \$3,000 cost.
Malicious human (interference) — DDOS attack. High	Firewall is configured properly and has good DDOS mitigation. Low	Website Critical	Website resources will be unavailable. Critical	Medium DDOS was discovered once in 2 years.	Medium Potential loss of \$10,000 per hour of downtime	Monitor the firewall.
Natural disasters — Flooding High	Server room is on the 3 rd floor. Low	Servers. Critical	All services will be unavailable. Critical	Low Last flood in the area happened 10 years ago.	Low	No action needed.
Accidental human interference — Accidental file deletions High	Permissions are configured properly; IT auditing software is in place; backups are taken regularly. Low	Files on a file share Medium	Critical data could be lost but almost certainly could be restored from backup. Low	Medium	Low	Continue monitoring permissions changes, privileged users and backups.



Calculating Cost

- ❶ Threat likelihood = medium = 0.5 (scale – 0 to 1)
- ❷ Threat impact = high = 1
- ❸ Total sensitive records = 1000
- ❹ Cost per sensitive record = 20
- ❺ Monetary risk = (Threat likelihood X threat impact) X (cost per item x total items) = $(0.5 \times 1) \times (20 \times 1000) = 10000$

Thank You!

Contact details:

Mob: +91 98230 80864

shweta@sccybersolutions.com

www.sccybersolutions.com

[@sccs1300](#)





- ❶ Some things to look for in an audit
 - ❧ Insufficient password complexity
 - ❧ Over permissive ACLs on folders
 - ❧ Inconsistent ACLs on folders
 - ❧ Non-existent or insufficient file activity auditing
 - ❧ Non-existent or insufficient review of auditing data
 - ❧ Correct security software and security configurations on all systems
 - ❧ Only compliant software installed on systems
 - ❧ Data retention policies followed
 - ❧ Disaster recovery plans updated and tested
 - ❧ Incident response plans updated and tested
 - ❧ Sensitive data stored and protected correctly with encryption
 - ❧ Change management procedures followed